

Acme Corp Information Security Policy

Version 3.0 — Approved by the Board Risk Committee

1. Governance

The Information Security Policy is approved annually by the Board Risk Committee and is reviewed against the organization's strategic objectives and risk appetite statement. The CISO reports directly to the Chief Executive Officer and provides quarterly cyber risk briefings to the Board.

2. Roles and Responsibilities

Section 2.4 lists high-level responsibilities for the Security Team. Business unit owners and third-party contract managers are expected to cooperate with the Security Team as needed.

3. Security Strategy

The organization maintains a 2023-2025 Security Roadmap aligned with business goals. The roadmap is reviewed annually by senior management.

4. Human Resources Security

All new hires undergo criminal record, education, and reference checks prior to onboarding, with enhanced checks for roles with privileged system access. New employees complete a security awareness module during onboarding.

5. Third Party Security

Standard vendor contracts include Annex C: Information Security Requirements, mandatory for any vendor accessing production systems. Vendor risk assessments are conducted at onboarding and upon contract renewal.

6. Access Management

MFA is mandatory for all VPN connections and for any account with administrative privileges, enforced via the corporate IdP. Access is revoked within 5 business days of termination.

7. Incident Management

The Incident Response Plan (Appendix D) defines a 4-tier severity classification, escalation matrix, and a 72-hour SAMA notification requirement for material incidents.